

1) A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system.

Aim

To analyze the Nmap scan report of the target system (192.168.1.10), identify security risks associated with the open ports, discuss possible attack methods, and recommend security measures to protect the system.

Code Used

Basic Nmap Scan

```
nmap 192.168.1.10
```

Purpose:

- Checks whether the target host is active.
- Displays open ports.

Advanced Nmap Scan

```
nmap -A 192.168.1.10
```

Purpose:

- Detects the operating system.
- Identifies service versions.
- Performs script scanning.
- Executes traceroute.

Detailed Scan of Specific Ports

```
nmap -sS -sV -O -A -p 22,80,3306 192.168.1.10 -oN report.txt
```

Explanation of the Options

Option	Description
➤ nmap	Starts the Nmap tool
➤ -sS	Performs a TCP SYN (Stealth) Scan
➤ -sV	Detects the version of running services
➤ -O	Detects the operating system
➤ -A	Enables OS detection, version detection, script scanning, and traceroute
➤ -p	Specifies the ports to scan
➤ -oN	Saves the output in a normal text file

Sample Nmap Report

Starting Nmap 7.95

Nmap scan report for 192.168.1.10

Host is up (0.0008s latency).

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 8.2

80/tcp open http Apache HTTP Server 2.4.41

3306/tcp open mysql MySQL 8.0.28

Device type: General Purpose

Running: Linux 5.x

OS details: Linux Kernel 5.x

Nmap done: 1 IP address (1 host up) scanned.

Analysis of the Nmap Report

The scan shows that the target system has three open ports:

- SSH (22)

- HTTP (80)
- MySQL (3306)

The operating system is identified as Linux 5.x, and the versions of the running services are also detected.

Open ports indicate that these services are available to users over the network. If they are not properly secured, attackers may attempt to exploit them.

Security Risks

1. SSH (Port 22)

Description

SSH (Secure Shell) is used for secure remote login and remote administration.

Risks

- Weak passwords may allow brute-force attacks.
- Old SSH versions may contain security vulnerabilities.
- Root login can provide attackers with full system access.

Possible Exploitation

An attacker may:

- Try thousands of username/password combinations.
- Exploit vulnerabilities in outdated OpenSSH versions.
- Gain unauthorized remote access.

Security Measures

- Use strong passwords.
- Disable root login.
- Enable SSH key authentication.
- Change the default SSH port.

2. HTTP (Port 80)

Description

HTTP is used to host websites and web applications.

Risks

- Web application vulnerabilities.
- SQL Injection.
- Cross-Site Scripting (XSS).
- Directory traversal.
- Information disclosure.

Possible Exploitation

Attackers may:

- Inject malicious SQL commands.
- Upload malicious files.
- Exploit outdated Apache vulnerabilities.
- Access restricted files.

Security Measures

- Update Apache regularly.
- Validate user input.
- Use HTTPS instead of HTTP.
- Install a Web Application Firewall (WAF).
- Disable unnecessary modules.

3. MySQL (Port 3306)

Description

MySQL stores application and website databases.

Risks

- Weak database passwords.
- Remote database access.
- Database vulnerabilities.
- Unauthorized access to sensitive data.

Possible Exploitation

Attackers may:

- Guess database passwords.
- Steal confidential information.
- Modify or delete records.
- Escalate privileges.

Security Measures

- Disable remote access if unnecessary.
- Use strong passwords.
- Restrict access using firewall rules.
- Regularly update MySQL.
- Encrypt sensitive data.

Operating System Risks

The scan detected Linux 5.x.

Knowing the operating system helps attackers:

- Search for publicly known vulnerabilities.
- Use operating system-specific exploits.
- Plan attacks based on Linux services.

Security Measures

- Install security patches regularly.
- Disable unnecessary services.
- Configure firewalls properly.
- Use intrusion detection systems.
- Perform regular vulnerability assessments.

Overall Security Risks

The scan provides attackers with valuable information, including:

- Open ports
- Running services
- Service versions
- Operating system details

This information can be used to identify known vulnerabilities and plan targeted attacks.

Recommended Security Measures

1. Keep the operating system and all services updated.
2. Close unused ports.
3. Configure firewall rules to allow only required traffic.
4. Use strong passwords and multi-factor authentication.
5. Disable unnecessary services.
6. Restrict MySQL remote access.
7. Enable HTTPS instead of HTTP.
8. Monitor system logs regularly.
9. Perform periodic vulnerability assessments.
10. Use intrusion detection and prevention systems (IDS/IPS).

Conclusion

The Nmap scan identified three important services running on the target system: SSH (22), HTTP (80), and MySQL (3306). Each service introduces potential security risks if not properly configured or updated. Attackers can exploit weak passwords, outdated software, or web application vulnerabilities to gain unauthorized access or steal sensitive data. Implementing strong authentication, regular software updates, firewall protection, secure configurations, and continuous monitoring significantly reduces the risk of successful attacks and improves the overall security of the target system.

2)A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. Using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(20 Mark).

Aim

To analyze the phishing awareness campaign conducted using the GoPhish tool, identify the security weaknesses demonstrated by employees, and recommend appropriate user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.

Tool Used

GoPhish:

GoPhish is an open-source phishing simulation tool used by organizations to conduct security awareness campaigns. It helps security teams measure employee awareness by sending simulated phishing emails and tracking user interactions such as email opens, link clicks, credential submissions, and attachment downloads.

Code / Steps Used

1. Start GoPhish

```
cd gophish
```

```
./gophish
```

2. Access the GoPhish Web Interface

Open a web browser and visit:

<https://127.0.0.1:3333>

Login using the administrator credentials.

3. Create an Email Template

Example phishing email:

Subject: Password Expiration Notice

Dear Employee,

Your company account password will expire today.

Please click the link below to reset your password immediately.

<http://abc-login-security.com>

Regards,

IT Support Team

4. Create a Landing Page

Example HTML page:

```
<!DOCTYPE html>
```

```
<html>
```

```
<head>
```

```
<title>Employee Login</title>
```

```
</head>
```

```
<body>
```

```
<h2>ABC Technologies Login</h2>
```

```
<form>
```

```
Username:<br>
```

```
<input type="text"><br><br>
```

```
Password:<br>
```

```
<input type="password"><br><br>
```

```
<input type="submit" value="Login">
```

```
</form>
```


</body>

</html>

5. Launch the Campaign

Create a campaign by selecting:

- Email Template
- Landing Page
- Employee Email Group
- SMTP Sending Profile

Click **Launch Campaign**.

6. Sample Campaign Report

Campaign Name : Employee Awareness Test

Total Employees : 100

Emails Sent : 100

Emails Opened : 85

Clicked Link : 40

Credentials Submitted : 20

Downloaded Attachment : 15

Campaign Status : Completed

Analysis of the Report

The GoPhish report shows the following employee behavior:

- **40%** of employees clicked the phishing link.
- **20%** entered their login credentials.
- Several employees downloaded a malicious attachment.

These results indicate that a significant number of employees failed to recognize common phishing indicators, making the organization vulnerable to social engineering attacks.

Security Weaknesses Demonstrated

1. Clicking Phishing Links

Weakness

Many employees clicked on suspicious links without verifying the sender or checking the legitimacy of the email.

Risk

Attackers can redirect users to fake websites designed to steal sensitive information or install malware.

2. Entering Login Credentials

Weakness

Some employees entered their usernames and passwords on a fake login page.

Risk

Attackers can steal user credentials and gain unauthorized access to company systems, email accounts, and confidential data.

3. Downloading Malicious Attachments

Weakness

Several users downloaded email attachments without confirming whether they were safe.

Risk

Malicious attachments may install ransomware, spyware, keyloggers, or other malware that can compromise the organization's systems.

4. Lack of Email Verification

Weakness

Employees trusted emails without verifying the sender's identity or inspecting suspicious content.

Risk

Attackers can impersonate trusted individuals or departments to trick employees into taking harmful actions.

5. Limited Security Awareness

Weakness

The report suggests that employees are not fully aware of phishing techniques and social engineering tactics.

Risk

Low awareness increases the likelihood of successful phishing attacks, leading to data breaches and financial losses.

Possible Attacks by Cybercriminals

If employees respond to phishing emails, attackers may:

- Steal usernames and passwords.
- Gain unauthorized access to company accounts.
- Install malware or ransomware.
- Steal confidential business information.
- Spread malware across the organization.
- Commit financial fraud or business email compromise (BEC).

Recommended User Awareness Programs

1. Regular Phishing Awareness Training

Conduct periodic training sessions to help employees recognize phishing emails, suspicious links, fake websites, and social engineering techniques.

2. Simulated Phishing Campaigns

Run regular phishing simulations using GoPhish to evaluate employee awareness and provide targeted training based on the results.

3. Cybersecurity Workshops

Organize workshops covering:

- Safe email practices
- Password security
- Multi-Factor Authentication (MFA)
- Identifying malicious attachments
- Reporting suspicious emails

4. Awareness Posters and Email Tips

Display cybersecurity awareness posters and send regular security newsletters with practical tips for identifying phishing attempts.

5. Reward Security-Conscious Employees

Recognize employees who correctly identify and report phishing emails to encourage a strong security culture.

Recommended Email Security Controls

1. Spam Filtering

Deploy advanced email filtering solutions to detect and block phishing emails before they reach users.

2. SPF, DKIM, and DMARC

Implement email authentication protocols to verify sender identity and reduce email spoofing.

3. Multi-Factor Authentication (MFA)

Require MFA for all employee accounts to reduce the impact of stolen passwords.

4. Attachment Scanning

Automatically scan email attachments for malware before delivery.

5. URL Filtering

Block or warn users before accessing known malicious websites and suspicious links.

6. Email Warning Banners

Add warning messages to emails received from external senders to help employees identify potentially risky messages.

Recommended Organizational Policies

1. Security Awareness Policy

Require all employees to complete cybersecurity awareness training regularly.

2. Password Policy

Enforce strong passwords, regular password changes, and prohibit password reuse.

3. Acceptable Use Policy

Define acceptable use of company email, internet access, and organizational resources.

4. Incident Reporting Policy

Require employees to immediately report suspicious emails, phishing attempts, or unusual system activity to the IT security team.

5. Email Usage Policy

Prohibit opening unexpected attachments or clicking links from unknown or suspicious senders without verification.

6. Regular Security Audits

Conduct periodic phishing simulations, vulnerability assessments, and policy reviews to improve the organization's security posture.

Conclusion

The GoPhish phishing awareness campaign revealed that a significant percentage of employees were vulnerable to phishing attacks. Forty percent clicked the phishing link, twenty percent disclosed their login credentials, and several users downloaded a malicious attachment, indicating gaps in security awareness. These actions could enable attackers to steal credentials, install malware, or compromise sensitive organizational data. To reduce the risk of successful social engineering attacks, ABC Technologies Pvt. Ltd. should implement regular user awareness training, conduct simulated phishing exercises, deploy strong email security controls such as SPF, DKIM, DMARC, and Multi-Factor Authentication, and enforce comprehensive organizational security policies. Together, these measures will strengthen employee awareness and improve the organization's overall cybersecurity resilience.

3)A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure

Aim

To analyze the DNS assessment report generated using the **Dig** tool, understand the security implications of a successful DNS Zone Transfer (AXFR), explain how attackers could exploit the exposed information, and recommend best practices to secure the DNS infrastructure.

Tool Used

Dig (Domain Information Groper)

Dig is a command-line utility used to query DNS (Domain Name System) servers. It helps administrators retrieve DNS records, troubleshoot DNS issues, and verify DNS configurations. It can also be used during security assessments to determine whether a DNS server incorrectly allows zone transfers.

Code Used

1. Display DNS Records

```
dig abc.com
```

Purpose:

Retrieves general DNS information for the specified domain.

2. Retrieve Name Server (NS) Records

```
dig abc.com NS
```

Purpose:

Displays the authoritative DNS servers responsible for the domain.

3. Retrieve Mail Server (MX) Records

```
dig abc.com MX
```

Purpose:

Displays the mail servers configured for the domain.

4. Perform DNS Zone Transfer (AXFR)

```
dig @ns1.abc.com abc.com AXFR
```

Purpose:

Attempts a DNS Zone Transfer from the DNS server. If successful, all DNS records stored on the server are displayed.

Sample Output

```
; <<>> DiG 9.18 <<>> @ns1.abc.com abc.com AXFR
```

abc.com. IN SOA ns1.abc.com admin.abc.com

abc.com. IN NS ns1.abc.com

abc.com. IN MX 10 mail.abc.com

www IN A 192.168.1.20

mail IN A 192.168.1.30

ftp IN A 192.168.1.40

database IN A 192.168.1.50

vpn IN A 192.168.1.60

admin IN A 192.168.1.70

Zone transfer completed.

Analysis of the Report

The DNS assessment shows that the DNS server allows a successful **DNS Zone Transfer (AXFR)**. As a result, an attacker can retrieve the complete DNS database, including:

- Internal hostnames
- Mail servers
- Web servers

- Database servers
- VPN servers
- Administrative systems
- DNS records

This information provides attackers with a detailed map of the organization's network infrastructure.

Security Implications

1. Exposure of Internal Hostnames

Risk

The report reveals the names of internal servers such as database, VPN, and admin systems.

Impact

Attackers can identify valuable targets for further attacks.

2. Exposure of Mail Servers

Risk

MX records reveal the organization's email servers.

Impact

Attackers may target these servers with phishing, spam, or email spoofing attacks.

3. Exposure of DNS Records

Risk

All DNS records become visible.

Impact

Attackers can identify web servers, file servers, application servers, and backup systems.

4. Network Reconnaissance

Risk

The entire network structure becomes visible.

Impact

Attackers spend less time gathering information before launching attacks.

5. Increased Attack Surface**Risk**

Previously unknown systems become discoverable.

Impact

Attackers can search for vulnerable or outdated services running on exposed hosts.

How Attackers Could Exploit These Findings

An attacker could:

- Identify important servers such as web, mail, VPN, and database servers.
- Launch targeted attacks against exposed systems.
- Scan identified hosts for vulnerabilities.
- Perform password guessing attacks on administrative systems.
- Conduct phishing campaigns using information about mail servers.
- Attempt unauthorized access to VPN or database servers.
- Use the information to plan larger cyberattacks.

Best Practices to Secure DNS Infrastructure**1. Disable Public Zone Transfers**

Allow DNS zone transfers only between trusted DNS servers.

2. Restrict AXFR Access

Configure the DNS server to permit AXFR requests only from authorized secondary DNS servers.

3. Use Firewalls

Restrict access to DNS services using firewall rules and allow only necessary traffic.

4. Enable DNSSEC

Implement DNS Security Extensions (DNSSEC) to protect DNS data from tampering and spoofing.

5. Keep DNS Software Updated

Regularly update DNS server software to fix security vulnerabilities.

6. Monitor DNS Logs

Continuously monitor DNS logs to detect suspicious queries and unauthorized zone transfer attempts.

7. Limit Information Exposure

Avoid publishing unnecessary internal hostnames or sensitive records in public DNS zones.

8. Perform Regular Security Audits

Regularly assess DNS configurations using tools like Dig to ensure secure settings and prevent information leakage.

Conclusion

The Dig assessment revealed that the organization's DNS server allows a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and other DNS records. This information can help attackers perform reconnaissance, identify critical systems, and launch targeted attacks. To protect the DNS infrastructure, organizations should disable unrestricted zone transfers, restrict AXFR to authorized servers, implement DNSSEC, use firewalls, monitor

DNS activity, and regularly audit DNS configurations. These measures significantly reduce the risk of information disclosure and strengthen the organization's overall cybersecurity posture.